

TPM fundamentals

08/15/2025

Applies to:  [Windows 11](#),  [Windows 10](#),  [Windows Server 2022](#),  [Windows Server 2019](#),  [Windows Server 2016](#)

This article provides a description of the Trusted Platform Module (TPM 1.2 and TPM 2.0) components, and explains how they're used to mitigate dictionary attacks.

A TPM is a microchip designed to provide basic security-related functions, primarily involving encryption keys. The TPM is installed on the motherboard of a computer, and it communicates with the rest of the system by using a hardware bus.

Devices that incorporate a TPM can create cryptographic keys and encrypt them, so that the keys can only be decrypted by the TPM. This process, often called "wrapping" or "binding" a key, can help protect the key from disclosure. Each TPM has a primary wrapping key, called the **storage root key**, which is stored within the TPM itself. The private portion of a storage root key, or **endorsement key**, that is created in a TPM is never exposed to any other component, software, process, or user.

You can specify whether encryption keys that the TPM creates can be migrated or not. If you specify that they can be migrated, the public and private portions of the key can be exposed to other components, software, processes, or users. If you specify that encryption keys can't be migrated, the private portion of the key is never exposed outside the TPM.

Devices that incorporate a TPM can also create a key wrapped and tied to certain platform measurements. This type of key can be unwrapped only when those platform measurements have the same values that they had when the key was created. This process is referred to as *sealing the key to the TPM*. Decrypting the key is called *unsealing*. The TPM can also seal and unseal data that is generated outside the TPM. With sealed key and software, such as BitLocker Drive Encryption, data can be locked until specific hardware or software conditions are met.

With a TPM, private portions of key pairs are kept separate from the memory that is controlled by the operating system. Keys can be sealed to the TPM, and certain assurances about the state of a system (assurances that define the trustworthiness of a system) can be made before the keys are unsealed and released for use. The TPM uses its own internal firmware and logic circuits to process instructions. Hence, it doesn't rely on the operating system and it isn't exposed to vulnerabilities that might exist in the operating system or application software.

- For information about which versions of Windows support which versions of the TPM, see [Trusted Platform Module technology overview](#).
- For more information about which TPM services can be controlled centrally by using Group Policy settings, see [TPM Group Policy Settings](#).

The features that are available in the versions are defined in specifications by the Trusted Computing Group (TCG). For more information, see the [Trusted Platform Module page](#) on the Trusted Computing Group website.

The following sections provide an overview of the technologies that support the TPM:

- [Measured Boot with support for attestation](#)
- [TPM-based Virtual Smart Card](#)
- [TPM-based certificate storage](#)
- [TPM Cmdlets](#)
- [Physical presence interface](#)
- [TPM 1.2 states and initialization](#)
- [Endorsement keys](#)
- [TPM Key Attestation](#)
- [Anti-hammering](#)

Measured Boot with support for attestation

The Measured Boot feature provides anti-malware software with a trusted (resistant to spoofing and tampering) log of all boot components. Anti-malware software can use the log to determine whether components that ran before it are trustworthy or infected with malware. It can also send the Measured Boot logs to a remote server for evaluation. The remote server can start remediation actions by interacting with software on the client or through out-of-band mechanisms, as appropriate.

TPM-based Virtual Smart Card

Warning

[Windows Hello for Business](#) and FIDO2 security keys are modern, two-factor authentication methods for Windows. Customers using virtual smart cards are encouraged to move to

Windows Hello for Business or FIDO2. For new Windows installations, we recommend Windows Hello for Business or FIDO2 security keys.

The Virtual Smart Card emulates the functionality of traditional smart cards. Virtual Smart Cards use the TPM chip, rather than using a separate physical smart card and reader. This greatly reduces the management and deployment cost of smart cards in an enterprise. To the end user, the Virtual Smart Card is always available on the device. If a user needs to use more than one device, a Virtual Smart Card must be issued to the user for each device. A computer that is shared among multiple users can host multiple Virtual Smart Cards, one for each user.

TPM-based certificate storage

The TPM protects certificates and RSA keys. The TPM key storage provider (KSP) provides easy and convenient use of the TPM as a way of strongly protecting private keys. The TPM KSP generates keys when an organization enrolls for certificates. The TPM also protects certificates that are imported from an outside source. TPM-based certificates are standard certificates. The certificate can never leave the TPM from which the keys are generated. The TPM can also be used for crypto-operations through [Cryptography API: Next Generation \(CNG\)](#).

TPM Cmdlets

You can manage the TPM using Windows PowerShell. For details, see [TPM Cmdlets in Windows PowerShell](#).

Physical presence interface

For TPM 1.2, the TCG specifications for TPMs require physical presence (typically, pressing a key) for turning on the TPM, turning it off, or clearing it. These actions typically can't be automated with scripts or other automation tools unless the individual OEM supplies them.

TPM 1.2 states and initialization

TPM 1.2 has multiple possible states. Windows automatically initializes the TPM, which brings it to an enabled, activated, and owned state.

Endorsement keys

A trusted application can use TPM only if the TPM contains an endorsement key, which is an RSA key pair. The private half of the key pair is held inside the TPM and it's never revealed or accessible outside the TPM.

Key attestation

TPM key attestation allows a certification authority to verify that a private key is protected by a TPM and that the TPM is one that the certification authority trusts. Endorsement keys proven valid are used to bind the user identity to a device. The user certificate with a TPM-attested key provides higher security assurance backed up by nonexportability, anti-hammering, and isolation of keys provided by a TPM.

Anti-hammering

When a TPM processes a command, it does so in a protected environment. For example a dedicated micro controller on a discrete chip, or a special hardware-protected mode on the main CPU. A TPM is used to create a cryptographic key that isn't disclosed outside the TPM. It's used in the TPM after the correct authorization value is provided.

TPMs have anti-hammering protection that is designed to prevent brute force attacks, or more complex dictionary attacks, that attempt to determine authorization values for using a key. The basic approach is for the TPM to allow only a limited number of authorization failures before it prevents more attempts to use keys and locks. Providing a failure count for individual keys isn't technically practical, so TPMs have a global lockout when too many authorization failures occur.

Because many entities can use the TPM, a single authorization success can't reset the TPM's anti-hammering protection. This prevents an attacker from creating a key with a known authorization value and then using it to reset the TPM's protection. TPMs are designed to forget about authorization failures after a period of time so the TPM doesn't enter a lockout state unnecessarily. A TPM owner password can be used to reset the TPM's lockout logic.

TPM 2.0 anti-hammering

TPM 2.0 has well defined anti-hammering behavior. This is in contrast to TPM 1.2 for which the anti-hammering protection was implemented by the manufacturer and the logic varied widely throughout the industry.

For systems with TPM 2.0, the TPM is configured by Windows to lock after 32 authorization failures and to forget one authorization failure every 10 minutes. This means that a user could quickly attempt to use a key with the wrong authorization value 32 times. For each of the 32 attempts, the TPM records if the authorization value was correct or not. This inadvertently causes the TPM to enter a locked state after 32 failed attempts.

Attempts to use a key with an authorization value for the next 10 minutes wouldn't return success or failure. Instead, the response indicates that the TPM is locked. After 10 minutes, one authorization failure is forgotten and the number of authorization failures remembered by the TPM drops to 31. The TPM leaves the locked state and returns to normal operation. With the correct authorization value, keys could be used normally if no authorization failures occur during the next 10 minutes. If a period of 320 minutes elapses with no authorization failures, the TPM doesn't remember any authorization failures, and 32 failed attempts could occur again.

Windows doesn't require TPM 2.0 systems to forget about authorization failures when the system is fully powered off or when the system has hibernated. Windows requires that authorization failures are forgotten when the system is running normally, in a sleep mode, or in low power states other than off. If a Windows system with TPM 2.0 is locked, the TPM leaves lockout mode if the system is left on for 10 minutes.

The anti-hammering protection for TPM 2.0 can be fully reset immediately by sending a reset lockout command to the TPM, and providing the TPM owner password. By default, Windows automatically provisions TPM 2.0 and stores the TPM owner password for use by system administrators.

In some implementations, the TPM owner authorization value is stored centrally in Active Directory, and not on the local system. An administrator can execute `tpm.msc` and choose to reset the TPM lockout time. If the TPM owner password is stored locally, it's used to reset the lockout time. If the TPM owner password isn't available on the local system, the administrator must provide it. If an administrator attempts to reset the TPM lockout state with the wrong TPM owner password, the TPM doesn't allow another attempt to reset the lockout state for 24 hours.

TPM 2.0 allows some keys to be created without an authorization value associated with them. These keys can be used when the TPM is locked. For example, BitLocker with a default TPM-only configuration is able to use a key in the TPM to start Windows, even when the TPM is locked.

Rationale behind the defaults

Originally, BitLocker allowed from 4 to 20 characters for a PIN. Windows Hello has its own PIN for sign-in, which can be 4 to 127 characters. Both BitLocker and Windows Hello use the TPM to

prevent PIN brute-force attacks.

Windows 10, version 1607 and earlier used Dictionary Attack Prevention parameters. The Dictionary Attack Prevention Parameters provide a way to balance security needs with usability. For example, when BitLocker is used with a TPM + PIN configuration, the number of PIN guesses is limited over time. A TPM 2.0 in this example could be configured to allow only 32 PIN guesses immediately, and then only one more guess every two hours. This totals a maximum of about 4,415 guesses per year. If the PIN is four digits, all 9999 possible PIN combinations could be attempted in a little over two years.

Starting in Windows 10, version 1703, the minimum length for the BitLocker PIN was increased to six characters, to better align with other Windows features that use TPM 2.0, including Windows Hello. Increasing the PIN length requires a greater number of guesses for an attacker. Therefore, the lockout duration between each guess was shortened to allow legitimate users to retry a failed attempt sooner while maintaining a similar level of protection. In case the legacy parameters for lockout threshold and recovery time need to be used, make sure that GPO is enabled and [configure the system to use legacy Dictionary Attack Prevention Parameters setting for TPM 2.0](#).

TPM-based smart cards

The Windows TPM-based smart card, which is a virtual smart card, can be configured to allow sign in to the system. In contrast with physical smart cards, the sign-in process uses a TPM-based key with an authorization value. The following list shows the advantages of virtual smart cards:

- Physical smart cards can enforce lockout for only the physical smart card PIN, and they can reset the lockout after the correct PIN is entered. With a virtual smart card, the TPM's anti-hammering protection isn't reset after a successful authentication. The allowed number of authorization failures before the TPM enters lockout includes many factors.
- Hardware manufacturers and software developers can use the security features of the TPM to meet their requirements.
- The intent of selecting 32 failures as the lock-out threshold is to avoid users to lock the TPM (even when learning to type new passwords or if they frequently lock and unlock their computers). If users lock the TPM, they must wait 10 minutes or use other credentials to sign in, such as a user name and password.